Título em Português
Segurança da Informação e Conformidade com a LGPD em um Sistema de Gestão Escolar: o Caso EduControll

Resumo

Objetivo: apresentar a arquitetura de segurança da informação implementada no EduControll, sistema web de gestão escolar desenvolvido em Django, com foco em autenticação robusta, criptografia e conformidade com a Lei Geral de Proteção de Dados (BRASIL, 2018). Métodos: a metodologia técnica baseou-se na engenharia de uma arquitetura de monólito modular, utilizando banco de dados PostgreSQL (DRAGONI et al., 2017) e comunicação cifrada via TLS/HTTPS para mitigar ataques na camada de rede. Como mecanismos de segurança, implementou-se derivação de chaves via hash PBKDF2 com salt único (BIRYUKOV et al., 2016; BONNEAU et al., 2012), de acordo com as diretrizes do NIST (2017). Adotou-se também autenticação de dois fatores (2FA) baseada em TOTP (M'RAIHI et al., 2011; O'GORMAN, 2003), bloqueio de conta por falhas sucessivas e recuperação de senha. Os dados em repouso são protegidos por criptografia simétrica AES, com auditoria garantida por logs imutáveis para prevenção de vulnerabilidades web (OWASP, 2021; FONSECA et al., 2007; ZELLER & FELTEN, 2008). Resultados: em conformidade com a LGPD, o sistema mapeia as finalidades dos dados, aplica a minimização e gerencia o consentimento explícito. Os resultados comprovam a viabilidade técnica de aplicar o framework Privacy by Design (CAVOUKIAN, 2009) em um sistema acadêmico, estruturando a segurança desde a sua concepção fundamental (MCGRAW, 2004). Conclusão: conclui-se que a adoção de metodologias consolidadas de security by design é imperativa no desenvolvimento de software educacional para garantir a privacidade, a integridade dos acessos e a conformidade regulatória contínua.

Palavras-chave

Segurança da Informação; Framework Django; Autenticação Multifator; Criptografia; LGPD.

Title in English
Information Security and LGPD Compliance in a School Management System: the EduControll Case

Abstract
Objective: to present the information security architecture implemented in EduControll, a web-based school management system developed in Django, focusing on robust authentication, encryption, and compliance with the General Data Protection Law (BRAZIL, 2018). Methods: the technical methodology was based on the engineering of a modular monolith architecture, using a PostgreSQL database (DRAGONI et al., 2017) and encrypted communication via TLS/HTTPS to mitigate network layer attacks. As security mechanisms, key derivation via PBKDF2 hash with a unique salt (BIRYUKOV et al., 2016; BONNEAU et al., 2012) was implemented, according to NIST (2017) guidelines. Two-factor authentication (2FA) based on TOTP (M'RAIHI et al., 2011; O'GORMAN, 2003), account lockout due to successive failures, and password recovery were also adopted. Data at rest is protected by AES symmetric encryption, with auditing guaranteed by immutable logs to prevent web vulnerabilities (OWASP, 2021; FONSECA et al., 2007; ZELLER & FELTEN, 2008). Results: in compliance with LGPD, the system maps data purposes, applies minimization, and manages explicit consent. The results prove the technical feasibility of applying the Privacy by Design framework (CAVOUKIAN, 2009) in an academic system, structuring security from its fundamental conception (MCGRAW, 2004). Conclusion: it is concluded that adopting consolidated security by design methodologies is imperative in educational software development to guarantee privacy, access integrity, and continuous regulatory compliance.

Keywords
Information Security; Django Framework; Multi-factor Authentication; Encryption; LGPD.

Título en Español
Seguridad de la Información y Cumplimiento de la LGPD en un Sistema de Gestión Escolar: el Caso EduControll

Resumen

Objetivo: presentar la arquitectura de seguridad de la información implementada en EduControll, un sistema web de gestión escolar desarrollado en Django, enfocado en autenticación robusta, cifrado y cumplimiento de la Ley General de Protección de Datos (BRASIL, 2018). Métodos: la metodología técnica se basó en la ingeniería de una arquitectura de monolito modular, utilizando una base de datos PostgreSQL (DRAGONI et al., 2017) y comunicación cifrada vía TLS/HTTPS para mitigar ataques en la capa de red. Como mecanismos de seguridad, se implementó derivación de claves vía hash PBKDF2 con salt único (BIRYUKOV et al., 2016; BONNEAU et al., 2012), según las directrices del NIST (2017). También se adoptó autenticación de dos factores (2FA) basada en TOTP (M'RAIHI et al., 2011; O'GORMAN, 2003), bloqueo de cuenta por fallos sucesivos y recuperación de contraseña. Los datos en reposo están protegidos por cifrado simétrico AES, con auditoría garantizada por logs inmutables para la prevención de vulnerabilidades web (OWASP, 2021; FONSECA et al., 2007; ZELLER & FELTEN, 2008). Resultados: en cumplimiento de la LGPD, el sistema mapea las finalidades de los datos, aplica minimización y gestiona el consentimiento explícito. Los resultados comprueban la viabilidad técnica de aplicar el framework Privacy by Design (CAVOUKIAN, 2009) en un sistema académico, estructurando la seguridad desde su concepción fundamental (MCGRAW, 2004). Conclusión: se concluye que la adopción de metodologías consolidadas de security by design es imperativa en el desarrollo de software educativo para garantizar la privacidad, la integridad de los accesos y el cumplimiento regulatorio continuo.

Palabras clave

Seguridad de la Información; Framework Django; Autenticación Multifator; Criptografía; LGPD.

Referências Bibliográficas

BIRYUKOV, A.; DUNAEV, D.; KHOVRATOVICH, D. Argon2: new generation of memory-hard functions for password hashing and other applications. IEEE European Symposium on Security and Privacy (EuroS&P), p. 292-302, 2016.

BONNEAU, J.; et al. The quest to replace passwords: A framework for comparative evaluation of web authentication schemes. IEEE Symposium on Security and Privacy, p. 553-567, 2012.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, 2018.

CAVOUKIAN, A. Privacy by design: The 7 foundational principles. Information and Privacy Commissioner of Ontario, v. 5, 2009.

DRAGONI, N.; et al. Microservices: how to make your application scale. Microservices: Science and Engineering, Springer, p. 21-39, 2017.

FONSECA, J.; VIEIRA, M.; MADEIRA, H. Testing and comparing web vulnerability scanning tools for SQL injection and XSS attacks. 13th Pacific Rim International Symposium on Dependable Computing (PRDC), IEEE, p. 365-372, 2007.

MCGRAW, G. Software security. IEEE Security & Privacy, v. 2, n. 2, p. 80-83, 2004.

M'RAIHI, D.; et al. RFC 6238: TOTP: Time-Based One-Time Password Algorithm. Internet Engineering Task Force (IETF), 2011.

NIST. Digital Identity Guidelines. National Institute of Standards and Technology, Special Publication 800-63B, 2017.

O'GORMAN, L. Comparing passwords, tokens, and biometrics for user authentication. Proceedings of the IEEE, v. 91, n. 12, p. 2021-2040, 2003.

OWASP. Top 10 Web Application Security Risks. Open Web Application Security Project, 2021.

ZELLER, W.; FELTEN, E. W. Cross-site request forgeries: Exploitation and prevention. Technical Report, Princeton University, 2008.

Nota de Integridade: O presente resumo científico e o sistema associado foram desenvolvidos de forma autoral pelo grupo. Ferramentas de Inteligência Artificial Generativa foram utilizadas estritamente como apoio para estruturação textual, tradução e adequação da contagem de palavras, havendo curadoria, validação humana e revisão crítica integral da documentação e das referências acadêmicas por parte dos autores, em conformidade com as diretrizes do Projeto Integrador.